



OPENCHAIN PROJECT: MANAGING OPEN SOURCE COMPLIANCE ACROSS THE SOFTWARE SUPPLY CHAIN

Shane Coughlan,
OpenChain general manager, Linux Foundation

One of the key requirements for any quality open source program is to comply with the requirements of open source licences. Companies, especially new entrants to the field, often have a lot of questions about what processes to follow, the methods of compliance and what challenges may be involved. The OpenChain Project by the Linux Foundation is a standard developed to solve and answer all these questions. To understand more about the OpenChain Project, **Ankita K.S.** from the **EFY Group** had a chat with **Shane Coughlan, OpenChain general manager** at the **Linux Foundation**.

Q Could you give us the background for the OpenChain Project?

The OpenChain initiative began in 2013, when two emerging patterns were observed in relation to the source code or devices of a group of companies from the global software supply chain. First, there were significant process similarities that existed among organisations with mature open source compliance programs. Second, there were many organisations exchanging software with less developed programs, which could result in a lack of trust regarding the consistency and the quality of the compliance artefacts and software being exchanged. Therefore, at each tier of the software supply chain, downstream organisations were frequently redoing the compliance

work already performed by other upstream organisations.

Q What are the key challenges that the typical software supply chain faces?

The supply chain does not have an obvious way to identify software, to communicate this identification and to manage everything with a clear replicable process. The OpenChain Project and its sister SPDX Project provide ways to address these challenges.

Q What does the OpenChain Project focus on?

This project focuses on identifying and sharing the core components of a high quality open source compliance program. OpenChain Specification is a supply chain standard that establishes a trust relationship between suppliers

and purchasers. The OpenChain Project maintains a list of organisations that have a publicly-announced conformance program, though there may be companies in the supply chain that prefer to communicate this fact during procurement discussions. The Specification makes it straightforward for new organisations to join the circle of trust.

Q How does OpenChain help to make Free and Open Source Software (FOSS) more accessible to developers?

The OpenChain Project provides solutions in three parts. One is specific to the standard, and it deals with the type of process and the quality of a program or policy. This identifies the minimum level of processes that organisations of any size can use to address open source compliance issues, effectively.

The second is our self-certification that confirms that you have all the necessary programs and policies in place. OpenChain conformance can be done manually or via a free online self-certification questionnaire provided by the OpenChain Project. This builds trust between organisations in the supply chain. It makes procurement simpler for purchasers and conferring a preferred status easier for suppliers.

The third part relates to the education and reference materials, which offer many examples that help a company to get an idea of what can be done